

Alvarez Valdez Mildred Janelly – Actividad 01 – Análisis y planificación del pentest

1. Objetivo del pentest

- A. Identificar la superficie de ataque para entender los riesgos a los que está expuesta la aplicación web.
- B. Determinar las afectaciones que podría tener la empresa en caso de que aumente o se materialice el riesgo.
- C. Proponer/proporcionar medidas de mitigación y recomendaciones de seguridad para reducir los riesgos identificados.
- D. Entregar información clara y útil que permita tomar mejores decisiones de seguridad.

2. Alcance

- A. Dentro del alcance (qué sí se evalúa)
 - a. Aplicación web.
 - b. Base de datos.
 - c. Mecanismos de autenticación.
 - d. Diferentes tipos de usuarios (roles)
- B. Fuera del alcance (qué no se evalúa)
 - a. Redes sociales de la empresa.
 - b. Equipos personales de los empleados.
 - c. Cuentas de correo.
 - d. Proveedores externos ni otros sistemas que no se encuentren dentro del alcance.

3. Autorización y condiciones

- A. Permisos requeridos
 - a. Autorización formal al equipo para realizar el ejercicio dentro del alcance previsto.
- B. Condiciones acordadas
 - a. La evaluación deberá realizarse únicamente sobre la aplicación web autorizada.
 - b. No se deben atacar redes sociales, equipos, correos, proveedores ni otros sistemas fuera del alcance.
 - c. Realizar acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o afectar información de los clientes.
 - d. Las pruebas deben realizarse durante horarios de menor actividad para minimizar impactos.
 - e. Colaboración basada en confianza, transparencia y comunicación.

4. Tipo de pentest

Debido que conocemos una parte mínima de la infraestructura del cliente y es una tienda de comercio electrónico se deberá realizar un pentest de caja gris (Pentest gray-box), dentro de la categoría de aplicaciones web.

5. Planificación

a. Objetivos

- a) Identificar la superficie de ataque para entender los riesgos a los que está expuesta la aplicación web.
- b) Determinar las afectaciones que podría tener la empresa en caso de que aumente o se materialice el riesgo.
- c) Proponer/proporcionar medidas de mitigación y recomendaciones de seguridad para reducir los riesgos identificados.
- d) Entregar información clara y útil que permita tomar mejores decisiones de seguridad.

b. Alcance

- a) Dentro del alcance (qué sí se evalúa)
 - a. Aplicación web.
 - b. Base de datos.
 - c. Mecanismos de autenticación.
 - d. Diferentes tipos de usuarios (roles)
- b) Fuera del alcance (qué no se evalúa)
 - a. Redes sociales de la empresa.
 - b. Equipos personales de los empleados.
 - c. Cuentas de correo.
 - d. Proveedores externos ni otros sistemas que no se encuentren dentro del alcance.

c. Permisos y condiciones

- A. Permisos requeridos
 - a. Autorización formal al equipo para realizar el ejercicio dentro del alcance previsto.
- B. Condiciones acordadas
 - a. La evaluación deberá realizarse únicamente sobre la aplicación web autorizada.
 - b. No se deben atacar redes sociales, equipos, correos, proveedores ni otros sistemas fuera del alcance.
 - c. Realizar acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o afectar información de los clientes.
 - d. Las pruebas deben realizarse durante horarios de menor actividad para minimizar impactos.

- e. Colaboración basada en confianza, transparencia y comunicación.

d. Metodología por utilizar

Debido a que la prueba se llevará a cabo en una tienda en línea, se decidió utilizar la metodología OWASP ya que está enfocada a aplicaciones web y nos permitirá hacer uso de recursos proporcionados por especialistas para evaluar autenticación, control de acceso, inyecciones SQL, manejo de sesiones

e. Recopilación de información previa

Debido a que se cuenta con información limitada sobre la infraestructura y tecnologías utilizadas por Aurora Market, se realizará una fase de recolección de información con el objetivo de identificar la superficie de ataque de la aplicación web. Esta actividad se dividirá en recolección pasiva y activa.

- 1) **Recolección pasiva:** inicialmente se buscará obtener información del objetivo sin interactuar directamente con sus sistemas. Se realizarán búsquedas en motores de búsqueda para identificar información pública relacionada con la aplicación web, dominios y subdominios. También se realizará un análisis de DNS y consultas WHOIS para obtener información relacionada con el dominio y la infraestructura pública asociada.
Adicionalmente, se podrá realizar un examen de la información públicamente disponible del sitio web para identificar tecnologías, rutas, archivos indexados u otros elementos que permitan conocer mejor la superficie de ataque.
No se realizará investigación sobre las redes sociales de la empresa ni recopilación de información sobre sus empleados, debido a que estos elementos se encuentran explícitamente fuera del alcance del pentest.
- 2) **Recolección activa:** posteriormente se realizarán actividades que impliquen interacción directa con los activos autorizados. Se podrán realizar escaneos controlados de puertos sobre las direcciones IP identificadas y autorizadas para determinar qué servicios se encuentran expuestos.
También se realizará fingerprinting de los servicios encontrados con el objetivo de identificar, cuando sea posible, el software y versiones utilizadas. Esta información podrá utilizarse posteriormente para investigar vulnerabilidades conocidas asociadas con dichas tecnologías.
Sobre la aplicación web se realizará enumeración y análisis de sus funcionalidades para identificar páginas, directorios, endpoints, parámetros, mecanismos de autenticación, manejo de sesiones y diferencias entre los distintos tipos de usuarios. Debido a las restricciones establecidas, no se realizarán actividades de ingeniería social ni recolección activa de correos electrónicos de empleados, ya que las cuentas de correo y los empleados se encuentran fuera del alcance de la evaluación

f. Recursos necesarios

Para llevar a cabo el pentest será necesario contar con recursos técnicos y herramientas que permitan realizar las diferentes fases de la evaluación.

Recursos técnicos:

- Equipo de cómputo con un entorno destinado a pruebas de seguridad, por ejemplo, Kali Linux.
- Acceso a Internet para realizar actividades de recolección de información y análisis de la aplicación web.
- Navegador web y herramientas de desarrollo para interactuar y analizar las funcionalidades de Aurora Market.
- Herramientas de OSINT y motores de búsqueda para realizar recolección pasiva de información.
- Herramientas como nslookup, dig y WHOIS para obtener información relacionada con el dominio, registros DNS y posibles direcciones IP asociadas.
- Nmap para realizar escaneos controlados sobre los activos identificados y determinar puertos, servicios expuestos y realizar fingerprinting.
- Wappalyzer o WhatWeb para identificar tecnologías utilizadas por la aplicación web.
- Burp Suite u OWASP ZAP para interceptar y analizar las solicitudes y respuestas HTTP/HTTPS, parámetros, cookies y sesiones.
- Herramientas de análisis de vulnerabilidades que permitan identificar posibles debilidades sobre los activos encontrados, respetando las restricciones del ejercicio.

Recursos de apoyo y documentación:

- Autorización formal proporcionada por Aurora Market para realizar el pentest.
- Definición del alcance y las restricciones establecidas para el ejercicio.
- OWASP Web Security Testing Guide (WSTG) como referencia para realizar las pruebas sobre la aplicación web.
- Herramientas para registrar evidencias y documentar los resultados obtenidos durante las diferentes fases del pentest.

g. Programación del pentest

La ejecución del pentest se organizará por etapas, mismas que se describieron en los puntos anteriores, considerando que las pruebas activas deberán realizarse durante horarios de menor actividad, de acuerdo con las condiciones establecidas por Aurora Market, con el objetivo de minimizar posibles afectaciones a la operación.

6. Fases del pentest

A. Reconocimiento.

- a. Buscar información del objetivo, en este caso “Aurora Market”, ya que es una aplicación web se debe identificar los dominios y subdominios, las direcciones IP, las tecnologías que utiliza e identificar los servicios que estén expuestos a internet relacionados a la tienda de comercio electrónico.

- B. Análisis de vulnerabilidades
 - a. Al finalizar la parte de reconocimiento, se deben identificar vulnerabilidades o posibles puntos de entrada, en este caso al ser una aplicación web debe estar alojada en un servidor, por lo que una vulnerabilidad podría ser un servidor legacy que muchas veces al ser un software antiguo y no contar con actualizaciones de parches, tiene vulnerabilidades conocidas.
 - b. Se pueden hallar credenciales o configuraciones por defecto, como “user: admin password: admin”
 - c. Identificación de puertos abiertos.
 - d. Análisis de usuarios.
- C. Explotación
 - a. Con base en las vulnerabilidades encontradas comprobar que pueden utilizarse/explotarse.
 - b. Evaluar el impacto potencial que podría tener esa vulnerabilidad.
- D. Post-explotación
 - a. En caso de lograr explotar una vulnerabilidad y obtener acceso al sistema, se deberá determinar el nivel de acceso y los privilegios obtenidos.
 - b. Evaluar si a partir del acceso obtenido fue posible escalar privilegios o acceder a otros activos relacionados con la aplicación.
 - c. Determinar qué acciones fue posible realizar con los privilegios obtenidos, por ejemplo: acceder a información sensible, consultar bases de datos, agregar o eliminar usuarios, modificar archivos o acceder a funcionalidades restringidas.
- E. Informe
 - a. Se documentan todos los hallazgos, las vulnerabilidades existentes y en qué activos, el impacto en caso de que se exploten esas vulnerabilidades y proporcionar medidas para mitigar.

7. Investigación

Se seleccionó OWASP WSTG debido a que proporciona una guía específicamente orientada a la evaluación de seguridad de aplicaciones web y sus categorías se relacionan directamente con las funcionalidades y riesgos presentes en Aurora Market.

Su aplicación permitirá realizar el pentest de forma estructurada, comenzando por la recopilación de información y continuando con pruebas específicas sobre configuración, autenticación, autorización, sesiones, validación de entradas y lógica de negocio.

Además, resulta especialmente adecuada para investigar el incidente reportado por Aurora Market relacionado con la posible visualización de información perteneciente a otra cuenta, ya que contempla pruebas específicas de autorización y control de acceso.

Los resultados obtenidos permitirán identificar y validar vulnerabilidades, determinar su posible impacto y proporcionar medidas de mitigación y recomendaciones de seguridad.